

Lecture 11:

Access Control and Identity Management

Eleftheria Makri | Security

06/05/2026



Universiteit
Leiden

Bij ons leer je de wereld kennen

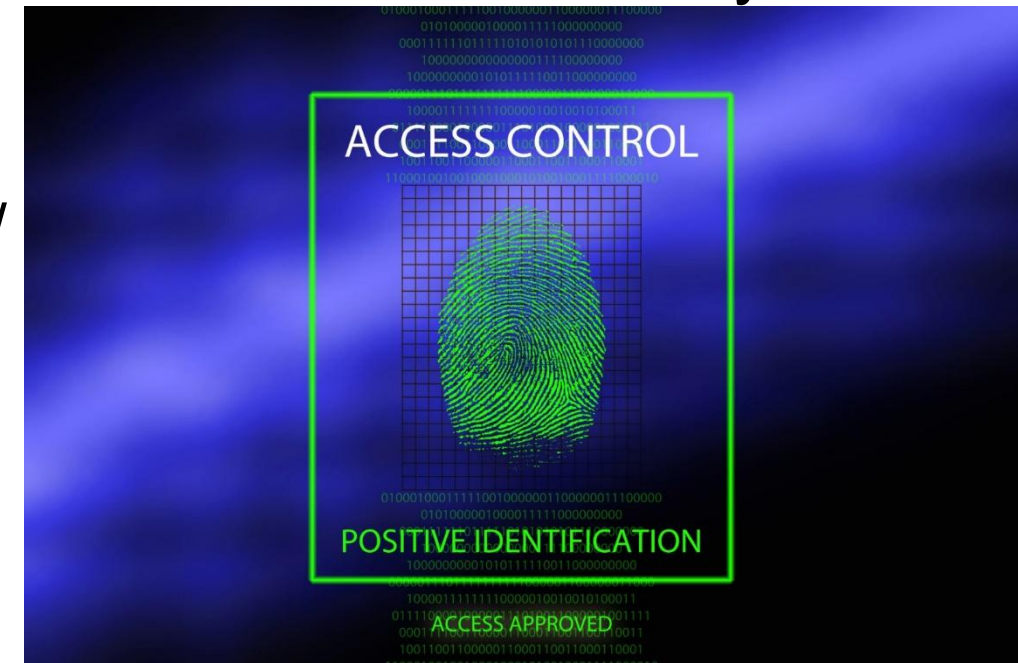
Access Control

- Terminology and definitions (+Identification & Authentication)
- Identity Management
- Access Control Policies
- Access Control Lists vs. Capabilities
- Access Control Privileges in Computer Systems
- Separation of Duties Constraints
- Multi-level Security Policies
 - The Bell-La Padula Model
 - The Biba Model
 - The Chinese Wall Model

Access Control

Controlling Access to a System

- Main steps of accessing a secure system:
 - **Identification:** stating who the user is
 - **Authentication:** verifying the identity claim
 - **Authorization:** granting access to resources based on identity
- **+ Accountability:** checking who was/
is accessing which resources



Identification



Authentication



Authorization
ALLOWED ACCESS YOU ARE NOT



Identification

Identification Badges



User ID

Login

enter your credentials

Username:

Password:

Login

Please enter a correct username and password

Account Number

 **ABN-AMRO**

Personal Commercial ▾ Private

Enter your question

Home Payments Savings Future income Investments Loans Mortgages Insurance

[back](#) **Log in with identification code** [to overview](#)


Go to log on with e.dentifier

Copy the account number from your card. If your card has an IBAN, please use the last 9 digits of your IBAN, as shown below.



Account number Card number

Account number

Card number

☐ Remember my account number and card number.

Your identification code 

[Forgotten your details?](#)

[choose identification code](#) [log on](#)

MAC Address

Network band:	2.4 GHz
Network channel:	1
IPv4 address:	192.158.5.105
IPv4 DNS servers:	192.158.0.5
Manufacturer:	Qualcomm Communications Inc
Description:	Qualcomm QCA5375 802.11ac V Adapter
Driver version:	12.0.5.445
Physical address (MAC):	9C-35-5B- 5F-4C-D7

Copy

IP Address

```
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Users\mevan33>ipconfig

Windows IP Configuration

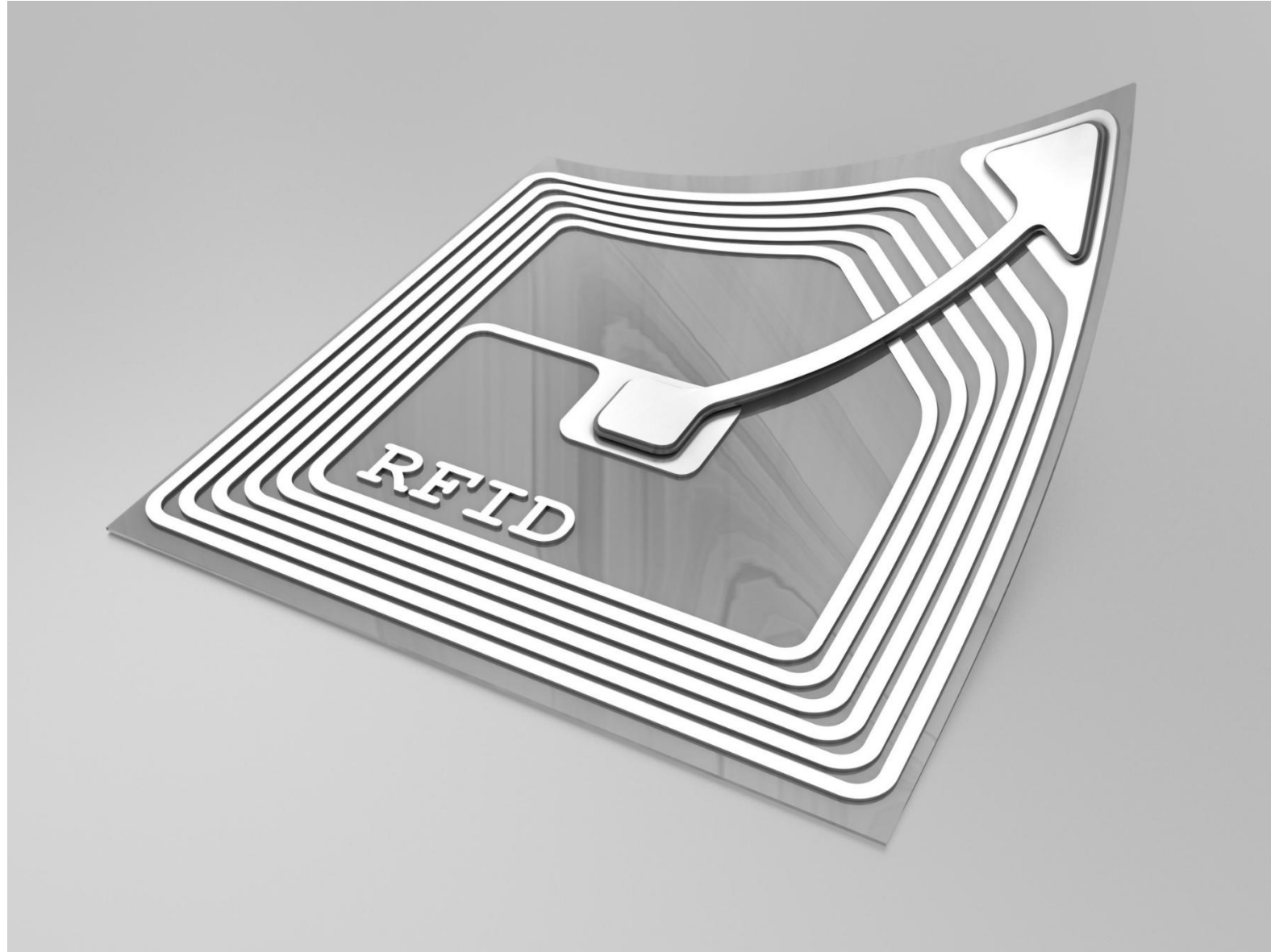
Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix . : 
    IPv6 Address. . . . . : 2620:105:b000:1180:34e3:4557:e884:f4d2
    IPv6 Address. . . . . : 2620:105:b000:1315:34e3:4557:e884:f4d2
    Temporary IPv6 Address. . . . . : 2620:105:b000:1180:ddc7:cbf2:843b:6f26
    Temporary IPv6 Address. . . . . : 2620:105:b000:1315:ddc7:cbf2:843b:6f26
    Link-local IPv6 Address . . . . . : fe80::34e3:4557:e884:f4d2%17
    IPv4 Address. . . . . : 130.39.193.138
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : fe80::2055:1:180:1%17
                                fe80::2055:1:315:1%17
                                130.39.193.1

Ethernet adapter Local Area Connection 3:

    Connection-specific DNS Suffix . :
```

Radio Frequency Identification (RFID)



E-mail Address



Authentication

Authentication Methods



**Something
you have**

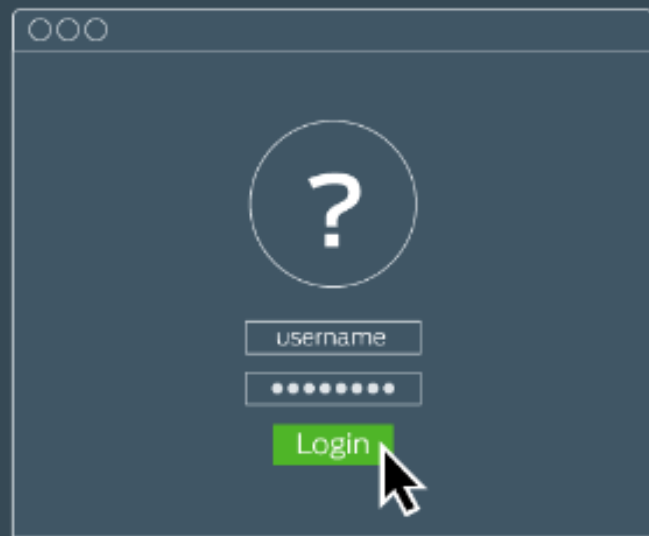


**Something
you are**



**Something
you know**

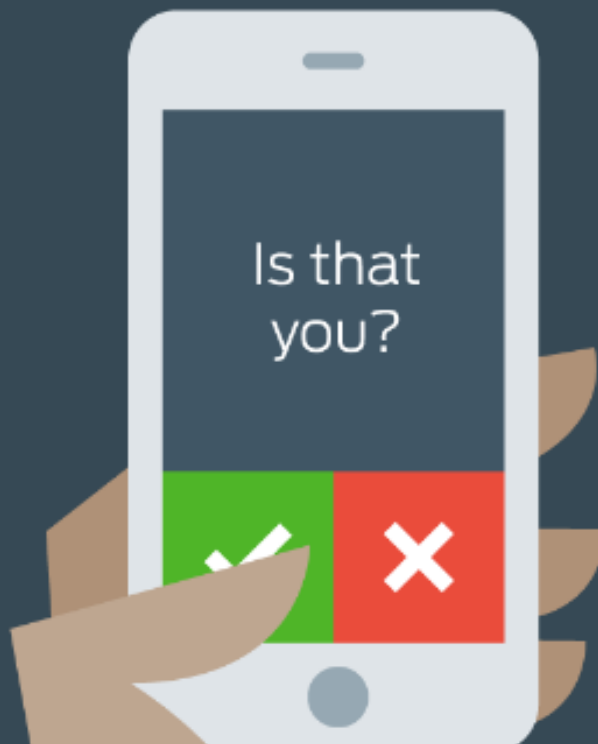
PASSWORD



A web browser window with a login form. It features a large question mark icon, a 'username' input field, a password field with dots, and a green 'Login' button. A mouse cursor is clicking the button.

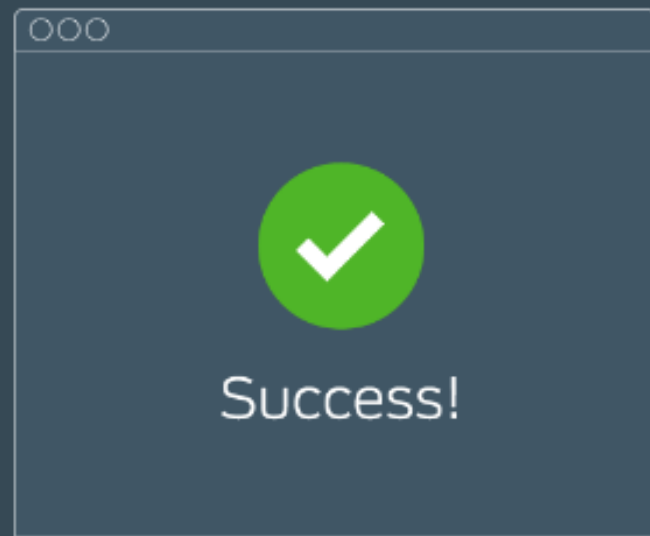
+

PROOF



=

ACCESS



Authentication Methods



Something
you have



Something
you are



**Something
you know**

Password:



**Strong
password**



**Using it for
multiple sites**

Authentication Methods



**Something
you have**

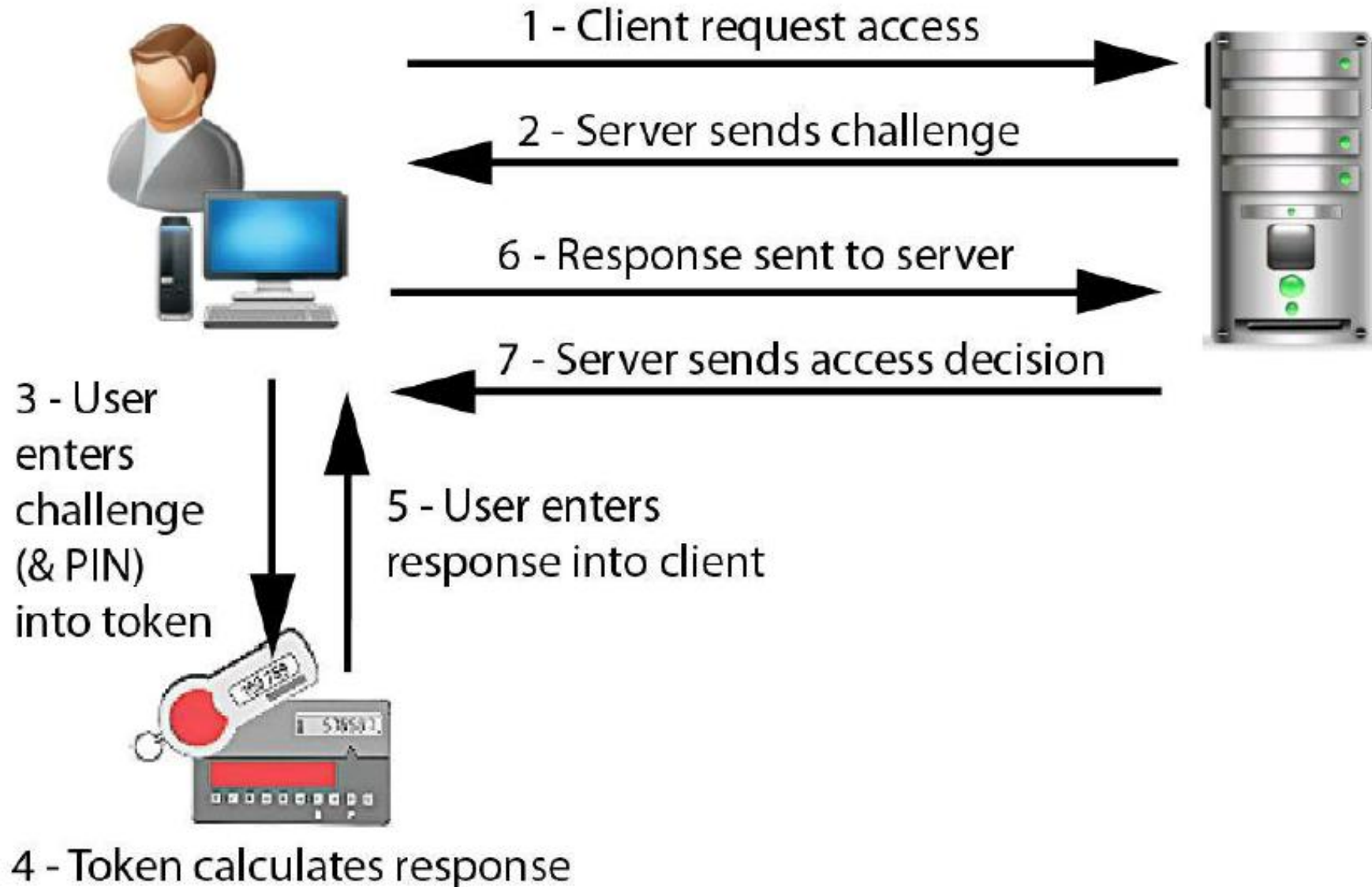


Something
you are

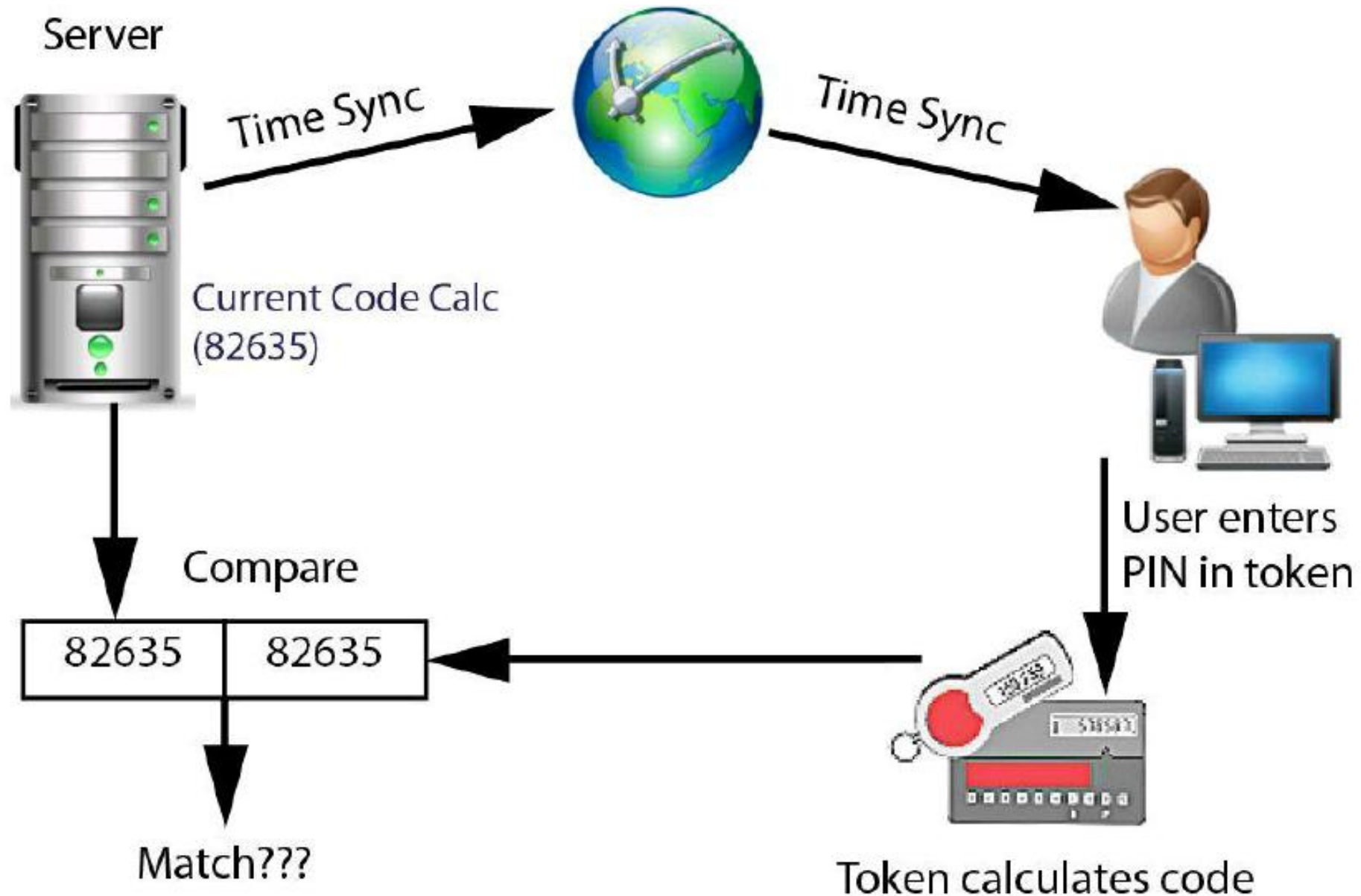


Something
you know

Asynchronous Authentication by possession



Synchronous Authentication by possession



Static Authentication Devices





Authentication Methods



Something
you have



**Something
you are**



Something
you know

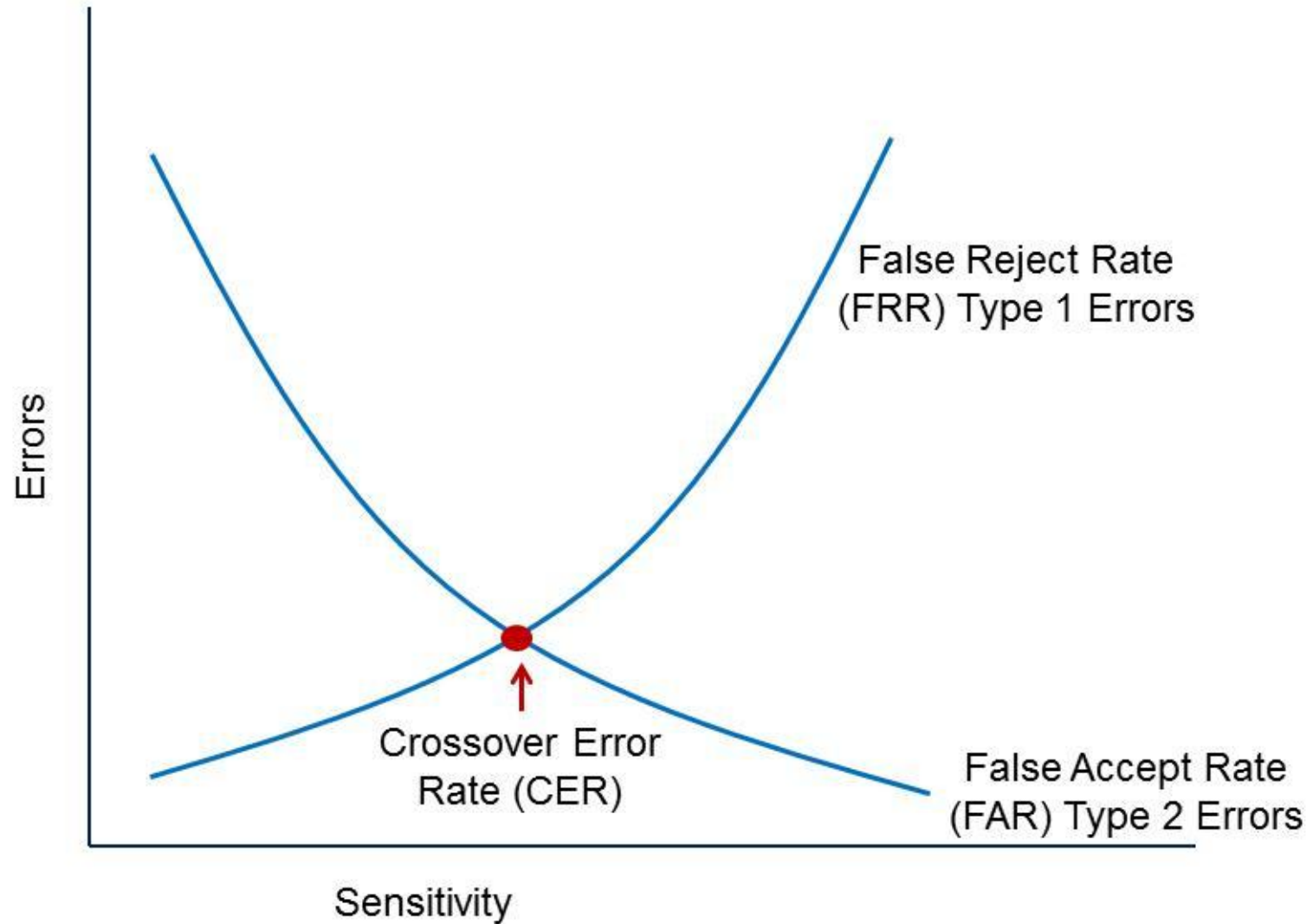
Physiological Biometrics



Behavioral Biometrics



Biometric Accuracy



Biometric Considerations

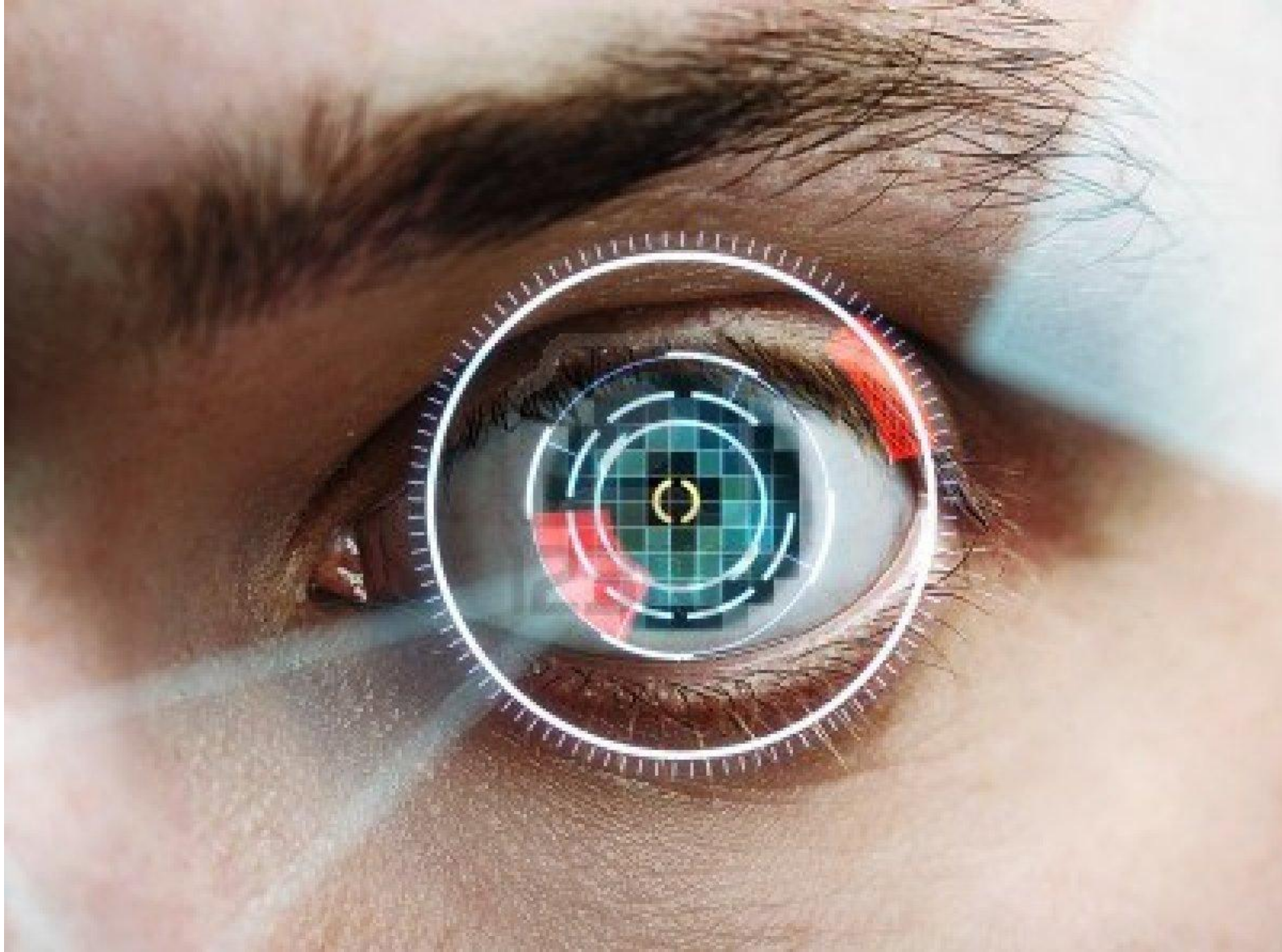
Resistance to Counterfeiting



Data Storage Requirements



User Acceptance



Reliability and Accuracy



Authentication Methods



**Something
you have**



**Something
you are**



**Something
you know**

Multifactor Authentication



Identity Management

Identity Management

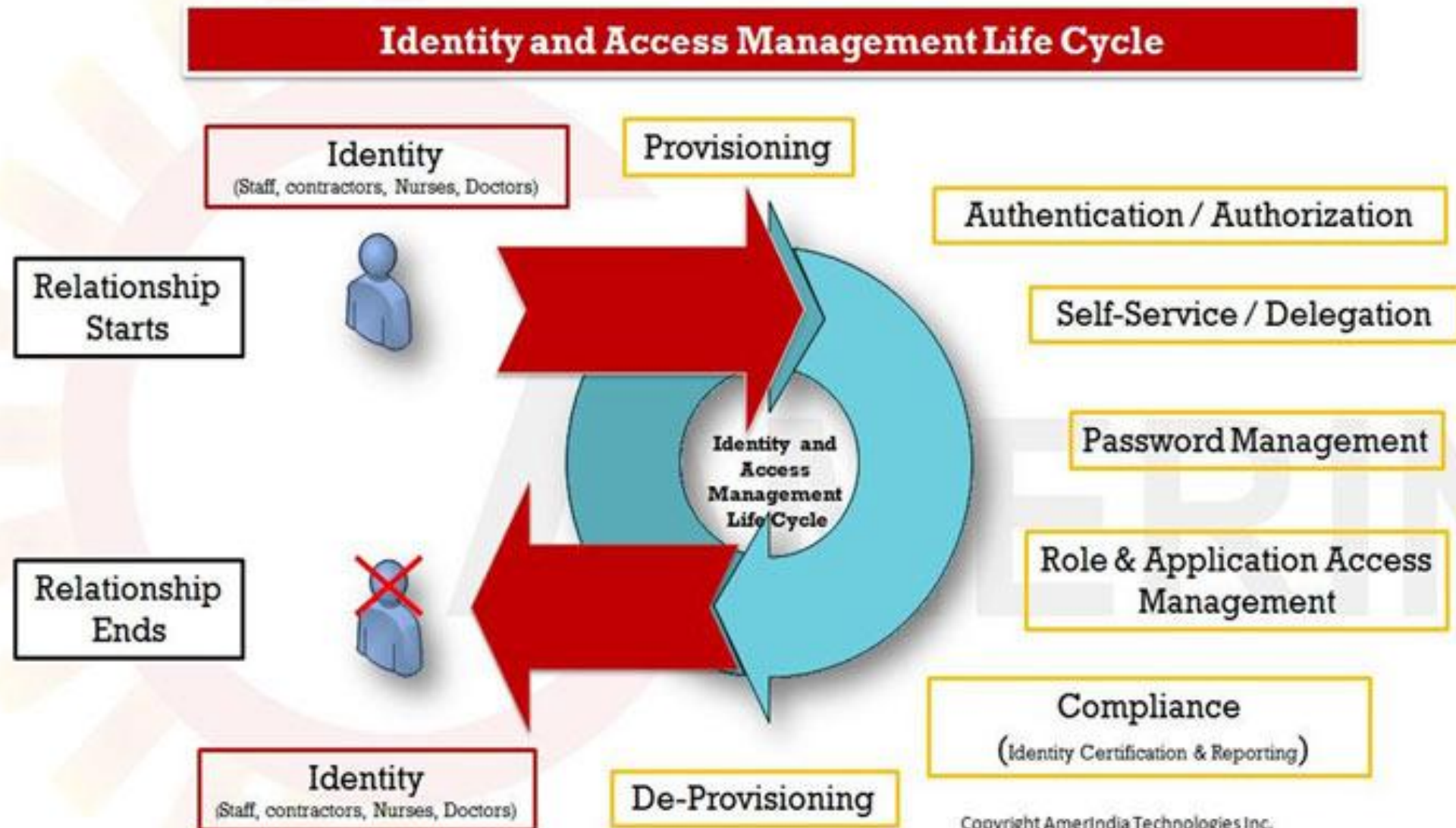
- **Identity management system** (IMS) is a system to *create*, *use*, and *revoke* user identities
 - can be tricky for large organizations and complex systems
 - various security requirements can apply depending on the use case:
 - privacy/anonymity/full transparency
 - strong link to physical identity
 - revocability
 - unforgeability
 - and others.

User vs. Identity vs. Subject

Identity-based authentication & authorization link 3 entities:

- User is a physical person (or a machine/an agent)
 - You
- (Internal) Identity is the entry in an IMS to which a user can be associated
 - Your group for appsec
- Subject is an entity in a system that can make actions/execute programs (needs privileges)
 - A binary or a shell script that you run

User Access Management



Access Control

- **Authentication** ensures user identity
- **Authorization** makes sure a subject acting with this identity can only access (has *privileges*) resources (objects) allowed for this identity
- **Audit** reviews the records of the system to check compliance with the policy
- **Access control policy** = “Who is allowed to access what?”
 - what types of access are permitted
 - under what circumstances
 - by whom

Access Control Policies

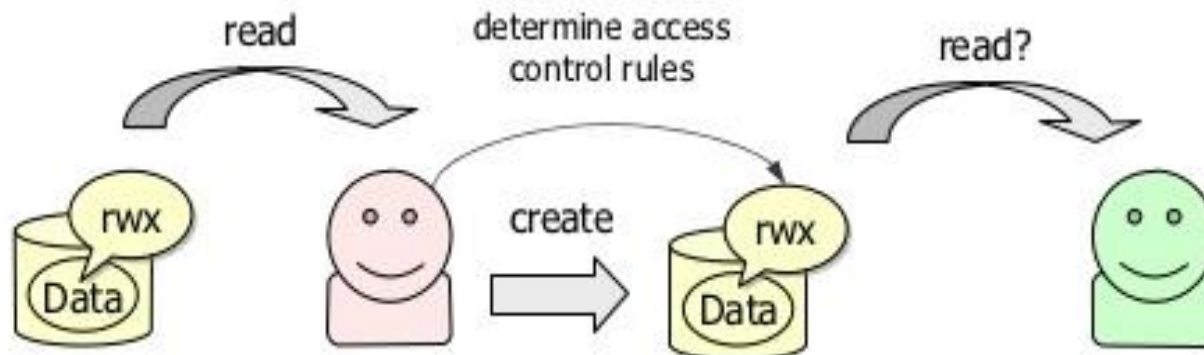
Access Control Policies

- Different classes of access control policies (schemes):
 - who sets and who controls the policy
 - access control rules are based on various groupings of identities
- **Examples (not mutually exclusive):**
 - **Discretionary Access Control (DAC)**
 - **Mandatory Access Control (MAC)**
 - **Non-Discretionary Access Control**
 - **Role-based access control (RBAC)**
 - **Attribute-based access control (ABAC)**
 - ...

Discretionary Access Control (DAC)

- **Principle:** owner of the resource defines who can access the resource
 - Typically implemented via ACLs
 - Users can belong to **groups**
 - Access rights are granted if the user has the right privilege or belongs to a group with the right privilege
 - User that has access rights can transfer these rights to other users (can be done indirectly)
- **Examples:** controls on social networks; file system access on UNIX systems (Android, Mac, etc.)
- **Issues:** easier to make mistakes; assumes all resources have owners

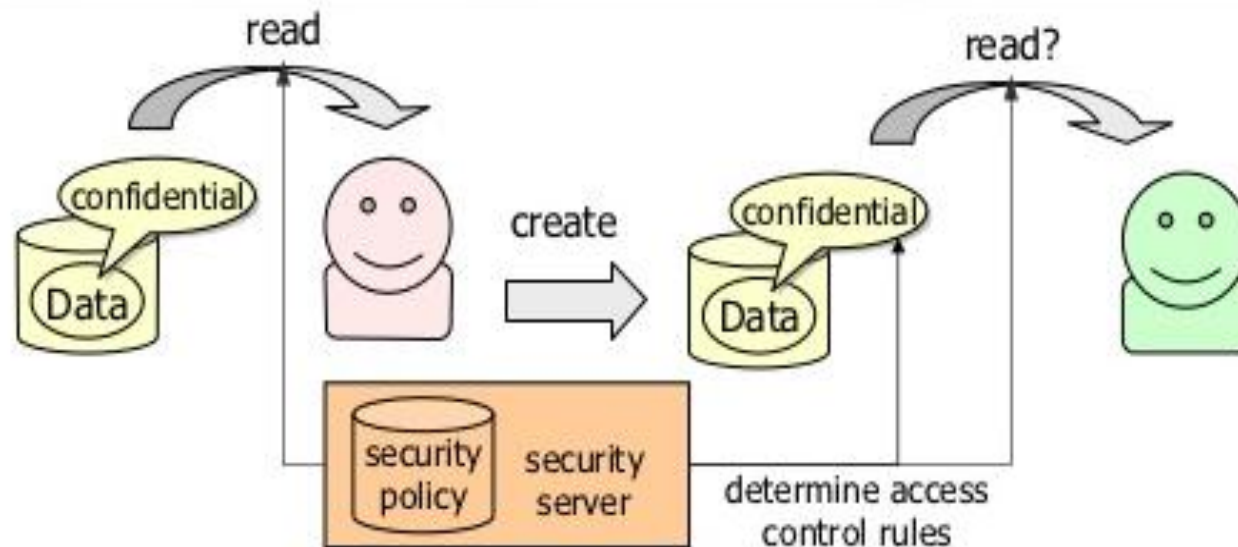
DAC (discretionary access control) : Owner decide access control rules



Mandatory Access Control (MAC)

- **Principle:** system-wide policy determines who can access a resource based on a sensitivity label
 - each resource and user have a sensitivity label
 - if they match, the user can access the resource
 - access rights **cannot** be transferred
- **Examples:** military security clearance systems, organization-wide policies
- **Issues:** more difficult to implement; quite rigid

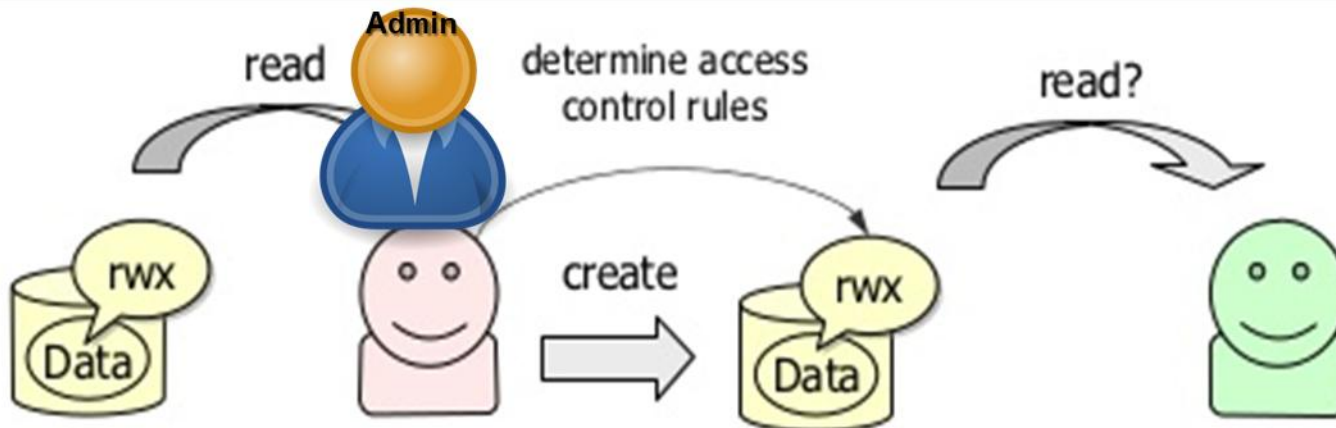
MAC (mandatory access control) : A centralized security policy decides access control rules



Non-Discretionary Access Control (NAC)

- **Principle:** admin defines who can access the resource
 - Typically implemented via ACLs
 - Users can belong to **groups**
 - Access rights are granted if the user has the right privilege or belongs to a group with the right privilege
 - User that has access rights **cannot** transfer these rights to other users (can be done indirectly)

NAC (Nondiscretionary Access Control): Administrator decide access control rules

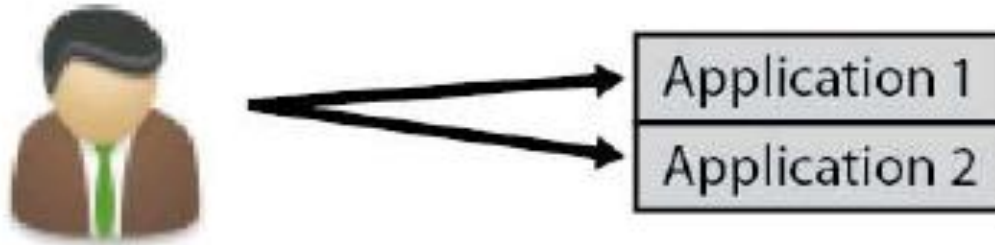


Role-Based Access Control (RBAC)

- DAC: users have access to objects
- RBAC: users have roles that have access to objects
- **Principle:** access control is based on roles that users assume in a system.
 - access is granted per role
 - users can have several roles
 - there can be *role hierarchies* and *constraints*
- **Example:** Brightspace (instructors can access hidden course parts, but cannot submit assignments; students cannot access hidden course parts, but can submit assignments)

Non-RBAC

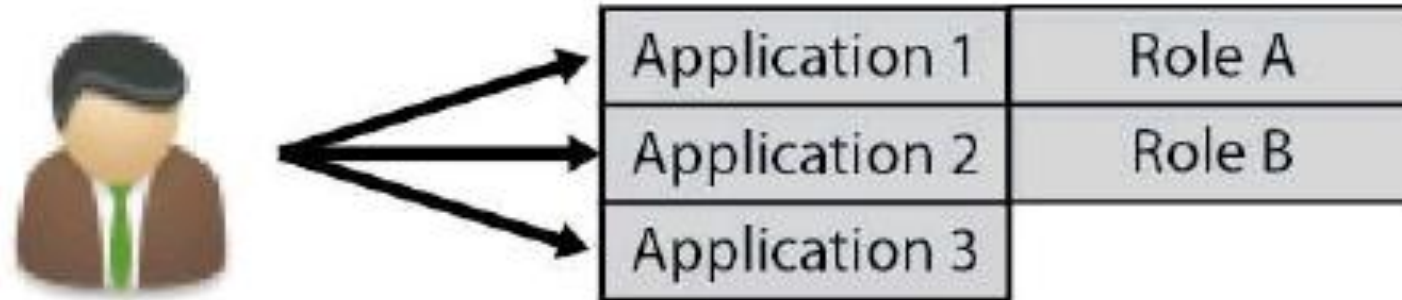
Non-RBAC Management



Users are mapped to applications

Limited RBAC

Limited RBAC Management

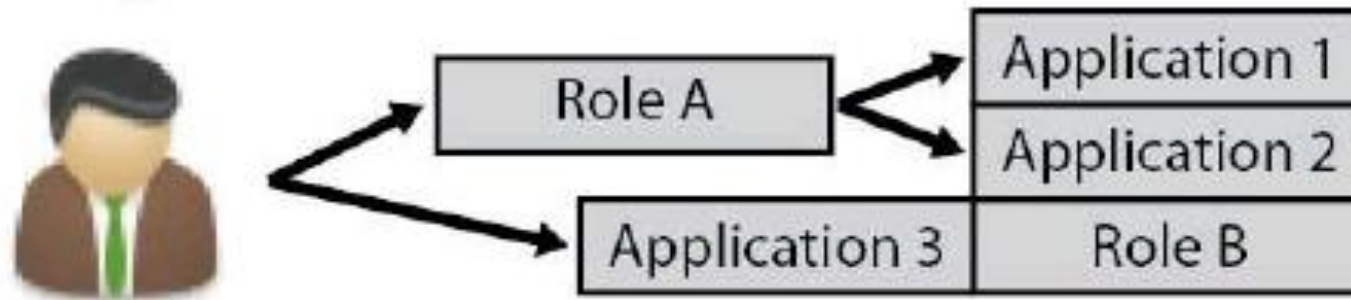


Users are mapped to application roles

Users ALSO mapped to applications that have not developed Role Based Access

Hybrid RBAC

Hybrid RBAC Management



Users are mapped to multi-application roles

Only select application access rights are moved to the multi-application role

Full RBAC

Full RBAC Management



Users are mapped to enterprise roles

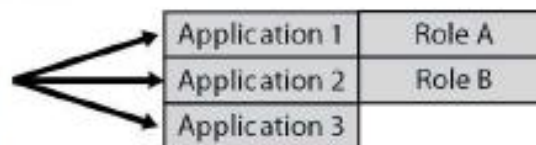
RBAC Synopsis

Non-RBAC Management



Users are mapped to applications

Limited RBAC Management



Users are mapped to application roles

Users ALSO mapped to applications that have not developed Role Based Access

Hybrid RBAC Management



Users are mapped to multi-application roles

Only select application access rights are moved to the multi-application role

Full RBAC Management



Users are mapped to enterprise roles

Access Control Lists (ACLs) vs. Capabilities

Data Access Controls

	Page/Namespace	User/Group	Permissions ¹⁾
#1	 *	 @ALL	☐ None ☐ Read ☐ Edit ☒ Create ☐ Upload ☐ Delete
#2	 *	 bigboss	☐ None ☐ Read ☐ Edit ☐ Create ☐ Upload ☒ Delete
#3	 devel: *	 @ALL	☒ None ☐ Read ☐ Edit ☐ Create ☐ Upload ☐ Delete
#4	 devel: *	 @devel	☐ None ☐ Read ☐ Edit ☐ Create ☒ Upload ☐ Delete
#5	 devel: *	 bigboss	☐ None ☐ Read ☐ Edit ☐ Create ☐ Upload ☒ Delete
#6	 devel: *	 @marketing	☐ None ☒ Read ☐ Edit ☐ Create ☐ Upload ☐ Delete
#7	 devel: funstuff	 bigboss	☒ None ☐ Read ☐ Edit ☐ Create ☐ Upload ☐ Delete
#8	 devel: marketing	 @marketing	☐ None ☐ Read ☒ Edit ☐ Create ☐ Upload ☐ Delete
#9	 marketing: *	 @marketing	☐ None ☐ Read ☐ Edit ☐ Create ☒ Upload ☐ Delete
#10	 start	 @ALL	☐ None ☒ Read ☐ Edit ☐ Create ☐ Upload ☐ Delete

Access Control Matrix

Access Control Matrix					
	Subject	File 1	File 2	File 3	File 4
Capability	Larry	Read	Read, write	Read	Read, write
	Curly	Full control	No access	Full control	Read
	Mo	Read, write	No access	Read	Full control
	Bob	Full control	Full control	No access	No access

Capability = row in matrix

ACL

Capability = row in matrix

ACL = column in matrix

ACLs vs. Capabilities

- An *ACL* (access control list) defines access rights per resource (file, directory)
 - simple to implement; harder to check access rights at runtime
- A *capability* defines access rights per user
 - runtime checks are easier, delegation is easy to implement; harder to modify access rights per a file.
- Both become too cumbersome to maintain in large and dynamic systems

Access Control Privileges in Computer Systems

Subject Classes

- Classes group subjects into categories:
 - **Owner**: the main entity that owns a resource (a creator or an administrator)
 - **Group**: membership of a subject in a group is sufficient to exercise some access rights [A user may belong to multiple groups]
 - **World**: least number of privileges that are granted to users who can access the system itself, but are not the owner and do not belong in a group
- Separate category: **superuser**

Access Control Privileges in Computer Systems

- **Read (r)** file or directory contents
- **Write (w)** modify file or directory contents
- **Execute (x)** a program file/access&search directory

access control lists
(ACLs)

	User	program OS	program CRM system	program CRM interface	file Customer list	program System log
user Admin Tanja		rwx	rwx	rwx	r	r
user Manager Alice		x	x	rwx	rw	-
program CRM interface		rx	rwx	rwx	rw	w
user Developer Bob		rx	rwx	rwx	r	-

access control matrix

Separation of Duties Constraints

Separation of Duties (SoD)



SoD Conflicts and Constraints

Function/ Processes \ Roles	Create Vendor	Change Vendor	Post Goods Receipt	Post Payment	Process Inventory	Goods Issue	Maintain PO
Create Vendor		X	X	X			X
Change Vendor	X		X	X			X
Post Goods Receipt	X	X		X	X	X	X
Post Payment	X	X	X			X	X
Process Inventory			X				X
Goods Issue			X	X			
Maintain PO	X	X	X	X	X		

X - Existence of Conflict

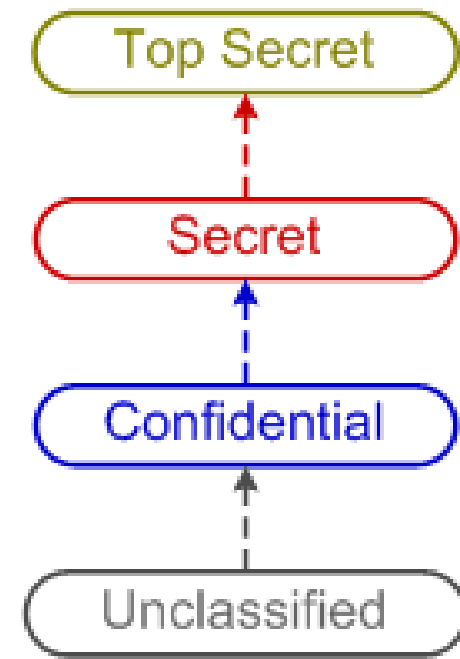
SoD Constraints

- Are used to limit opportunities for insider attacks
- **Constraint examples:**
 - A user may not have simultaneously roles $r1$ and $r2$ (ever or during a session)
 - A user in role $r1$ must also have role $r2$
 - At most (at least) k users must have role $r1$
 - four eyes principle; two signatures principle
- **Examples:** At least 2 professors evaluate a bachelor thesis; a student cannot be a student assistant in a course they take.

Multi-level Security Policies

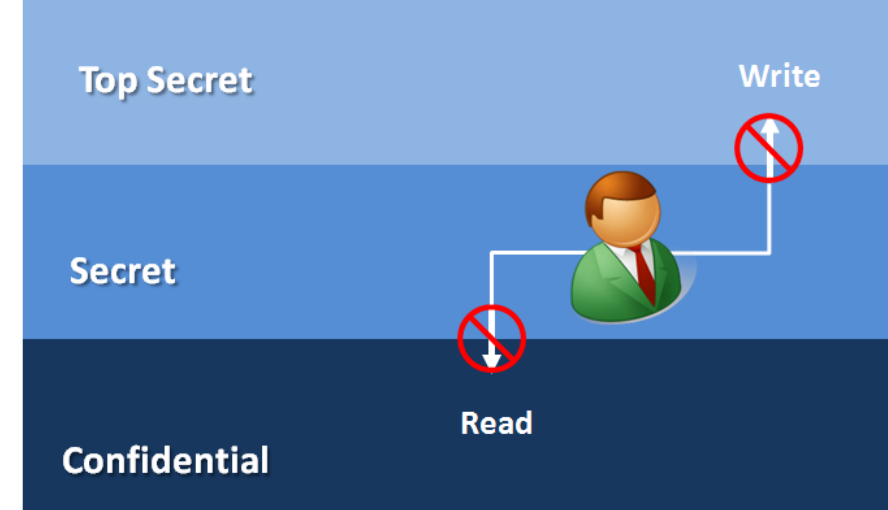
The Bell-La Padula Model

- **Principle:** Information cannot flow downwards
- Focuses on confidentiality
- Two properties are enforced:
 - *The simple security property:* no subject may read data from a higher level (no read up)
 - *The *-property:* no subject may write data to a lower level (no write down)
- The Bell-La Padula multi-level security model is basically a MAC
 - security policy is enforced system-wide



The Biba Model

- **Principle:** data may be visible to many users, but can only be modified by a user with the right privileges
- Focuses on integrity
- Enforced with two properties:
 - *Simple integrity:* a subject may only read data at an equal or higher level (no read down)
 - *Star Integrity:* a subject may only write data at an equal or lower level (no write up)
- **Example:** everybody can read a website, but only admins can update it.

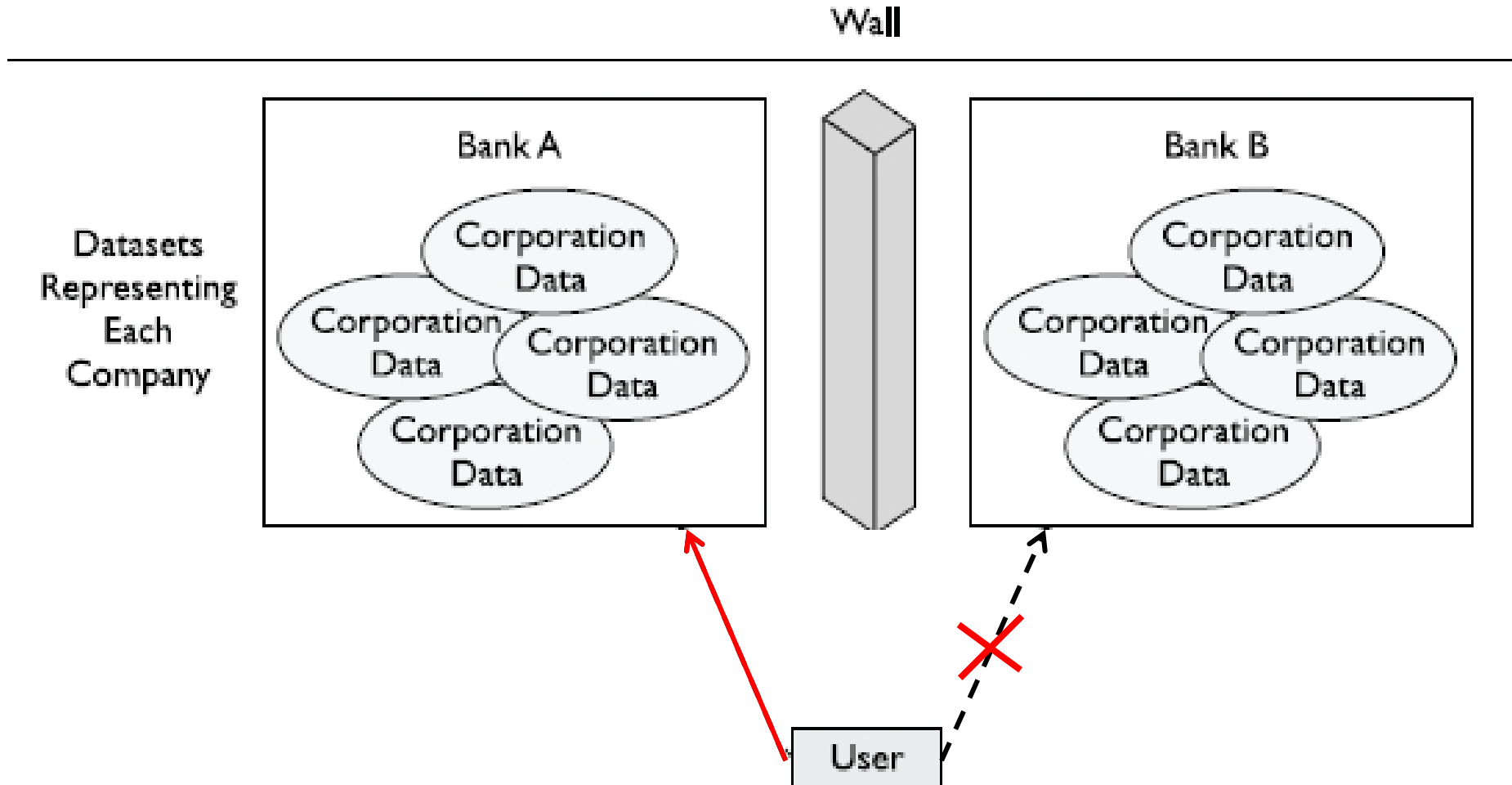


The Chinese Wall Model

- **Principle:** data may be visible to many users, only as long as no conflicts of interests arise
- Focuses on resolving Cols
- Enforced with two properties:
 - *Simple security:* a subject s can be granted access to an object o only if the object is in the same company datasets as the objects already accessed by s (within the Wall), or belongs to an entirely different Col class.
 - **-property:* Write access is only permitted if access is permitted by the simple security rule, and no object can be read from a different company dataset than the one for which write access is requested, and contains unsanitized information
- **Example:** In stock exchange and investment house: it prevents traders from representing clients with conflict interest.



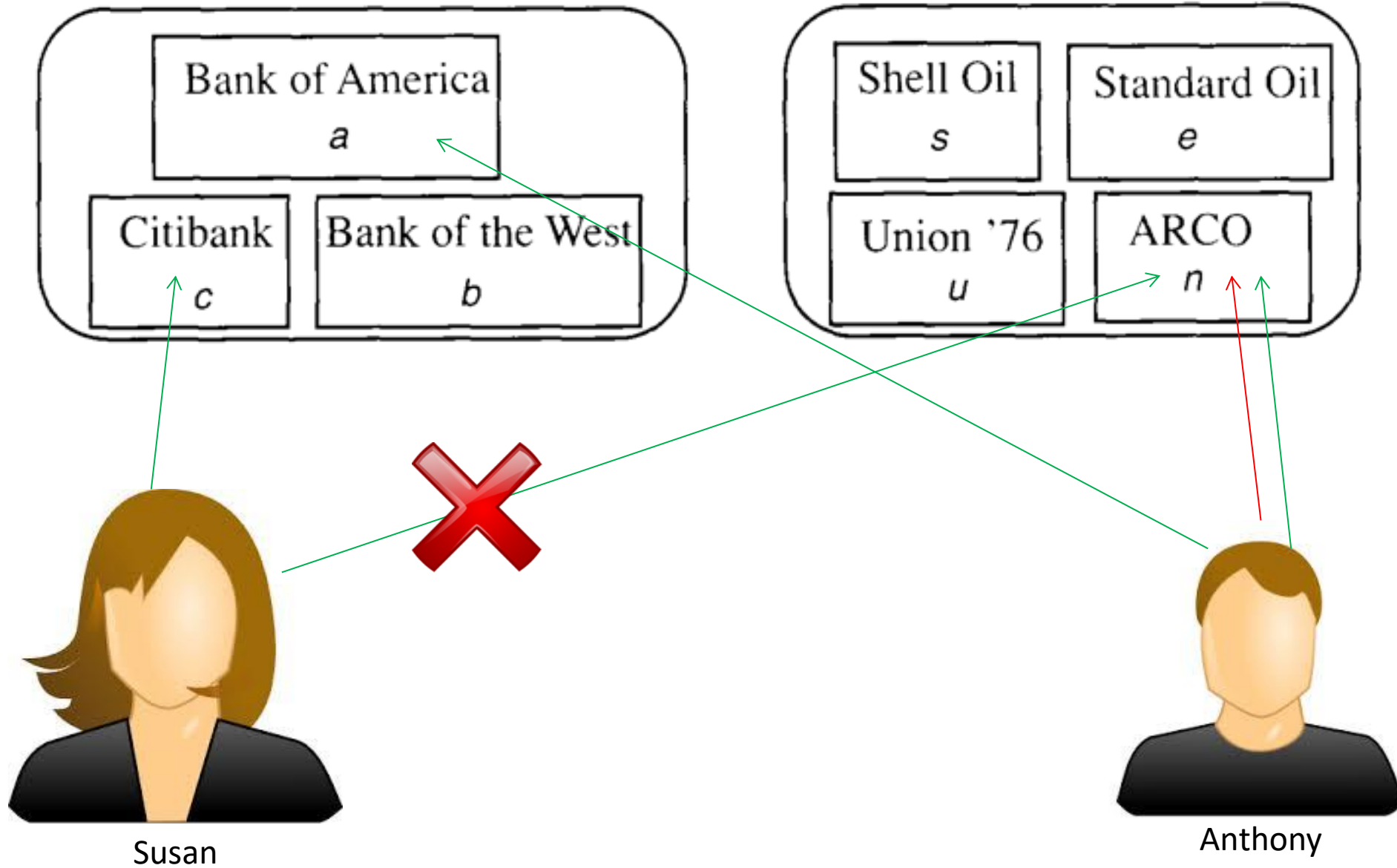
Chinese Wall Model – Example of dynamic permission change



Chinese Wall Model – Example of *-property

Bank COI Class

Gasoline Company COI Class



Access Control

- Terminology and definitions (+Identification & Authentication)
- Identity Management
- Access Control Policies
- Access Control Lists vs. Capabilities
- Access Control Privileges in Computer Systems
- Separation of Duties Constraints
- Multi-level Security Policies
 - The Bell-La Padula Model
 - The Biba Model
 - The Chinese Wall Model

References

- Dieter Gollmann, Authentication, Authorisation & Accountability (AAA) Knowledge Area, Available at:
https://www.cybok.org/media/downloads/AAA_issue_1.0_q3qspzo.pdf
- William Stallings and Lawrie Brown, Computer Security; Principles and Practice, Available at:
[https://www.cs.unibo.it/babaoglu/courses/security/resources/documents/Computer_Security_Principles_and_Practice_\(3rd_Edition\).pdf](https://www.cs.unibo.it/babaoglu/courses/security/resources/documents/Computer_Security_Principles_and_Practice_(3rd_Edition).pdf)
(Chapters 3 and 4)

Questions?



Universiteit
Leiden

Bij ons leer je de wereld kennen